

PLANO DE GESTÃO E RESPOSTA DE INCIDENTES DE SEGURANÇA

FOLHA DE CONTROLE INTERNO

PLANO DE GESTÃO E RESPOSTA DE INCIDENTES DE SEGURANÇA	
Criação	10/12/2025
Última atualização	11/12/2025
Versão vigente	1.0
Motivo atualização	Elaboração
Classificação da Informação	Interna
Responsável Operacional	Data Protection Officer Diretoria Empresas do GRUPO AZ Gestores do GRUPO AZ
Responsável Tático	Data Protection Officer
Responsável Estratégico	Alta Direção do Grupo (CEO)
Documentos relacionados	Política de Segurança Cibernética e da Informação Política de Governança de Dados Pessoais

PLANO DE GESTÃO E RESPOSTA DE INCIDENTES DE SEGURANÇA

1. OBJETIVO

O presente Plano de Gestão e Resposta de Incidentes de Segurança (o “**Plano**”) estabelece o procedimento para estruturar de forma rápida e ordeira a resposta a incidentes de segurança da informação que envolvam recursos e ativos do GRUPO AZ.

2. ABRANGÊNCIA E APLICABILIDADE

Este **Plano** tem aplicação imediata a partir da sua publicação e deverá ser seguida pelas pessoas físicas e jurídicas, prestadoras de serviços para o GRUPO AZ e parceiros comerciais.

O seu descumprimento será considerado **falta grave**, podendo resultar na aplicação de sanções, incluindo a rescisão do contrato.

3. LOCAL E DISPONIBILIDADE

Este documento está disponível para consulta em formato digital no diretório digital do GRUPO AZ.

4. RECONHECIMENTO DE UM INCIDENTE DE SEGURANÇA

Incidente de Segurança (o “**Incidente**”) é um evento ou condição, conhecida ou suspeita, que pode colocar em risco a confidencialidade, integridade, disponibilidade e/ou privacidade de ativos do GRUPO AZ e/ou sob sua responsabilidade e tutela. São, majoritariamente, situações em que ocorre o acesso não autorizado, ou situação acidental, ou ilícita, de destruição, perda, alteração, comunicação ou qualquer forma de tratamento de dados inadequado, acidental ou ilícito, sob guarda do GRUPO AZ.

Na tabela abaixo, alguns dos principais tipos de **Incidentes**:

Incidente	Descrição
Acesso não autorizado	Acesso indevido (permissões indevidas) em ambiente físico ou lógico.
Compartilhar ou distribuir dados pessoais com terceiros sem um fundamento legal que legitime a atividade de tratamento	O tratamento de dados pessoais será ilícito por não obter suporte em algum fundamento previsto na LGPD e, portanto, poderá ser considerado um vazamento de dados pessoais.

Falha ou erro de processamento (Ex.: execução de <i>script</i> de banco de dados que atualiza dado pessoal com informação equivocada, ausência de validação dos dados de entrada etc.)	Dados de entrada que não são corretamente validados, operações de tratamento automatizadas de sistema que alteram de maneira indevida a composição do dado armazenado.
Modificação não autorizada	Usuário sem permissão de alteração para um determinado dado pessoal ou registro realiza a modificação não autorizada. Um processamento indevido pode gerar uma modificação não autorizada.
Perda	Perdas provocadas por ações intencionais de usuários oriundas de uma exclusão indevida ou devida e não comunicada, e provenientes de ações não intencionais como falhas em sistemas, sobrescrita de dados, falhas em hardware, entre outras.
Reidentificação de dados (pseudo)anonimizados	Dados pessoais podem ser reidentificados por cruzamento simples de dados pessoais.
Remoção não autorizada	O usuário que executa a ação não tem a permissão para retirar ou copiar dados pessoais para outro local.
Subtração de dados pessoais	Dados pessoais subtraídos nas dependências internas do controlador/operador, falhas nos controles de segurança dos sistemas (a exemplo da ausência ou fraca criptografia, falha de sistema que permita escalação de privilégio ou tratamentos indevidos), entre outras.
Vinculação ou associação indevida, direta ou indireta, dos dados pessoais ao titular	A realização de operação de tratamento de dados pessoais deve se dar com qualidade de dados pessoais, ou seja, a sua exatidão, clareza, relevância e atualização, de acordo com a necessidade e para cumprimento da finalidade de seu tratamento. Qualquer atividade de tratamento de dados pessoais que não atenda a este requisito poderá produzir informações inadequadas, com vinculações ou associações indevidas.

5. ESTRUTURA DE RESPOSTA E GESTÃO DE INCIDENTES

5.1. Alta Direção

- Aprovar o Plano de Resposta e Gestão de Incidentes quando alinhado com os objetivos estratégicos do GRUPO AZ;
- Prestar o suporte e recursos necessários para manutenção do Plano de Resposta e Gestão de Incidentes do GRUPO AZ;
- Decidir pelo acionamento ou não deste **Plano**;
- Realizar a análise crítica dos indicadores de desempenho deste **Plano**;
- Supervisionar a aplicação deste **Plano** as ocorrências relatadas;
- Promover a conscientização e cultura de proteção de dados no GRUPO AZ.

5.2. Pessoa Gestora de Tecnologia

- Coordenar as atividades de execução do **Plano**;
- Avaliar tecnicamente e recomendar a classificação da ocorrência como uma falha ou um incidente de segurança;
- Validar este **Plano**;
- Realizar os registros necessários para evidenciar o cumprimento do Plano;
- Opinar pela contratação de terceiros para prestação de serviços de investigação forense, quando for o caso; e
- Implementar as melhorias técnicas eventualmente necessárias, no cumprimento do **Plano**.

5.3. Pessoa Data Protection Officer

- Apoiar a pessoa gestora de tecnologia na execução do **Plano**;
- Avaliar tecnicamente e recomendar estratégias de comunicação do incidente, quando envolver dados pessoais;
- Elaborar este **Plano**;
- Realizar os registros necessários para evidenciar o cumprimento do **Plano**;
- Opinar pela contratação de terceiros para prestação de serviços de investigação forense, quando for o caso;
- Realizar a comunicação, quando aplicável, sobre o incidente, para titulares afetados, partes interessadas e terceiros, incluindo órgãos regulatórios e judiciais;
- Analisar criticamente a ocorrência e definir a necessidade ou não de comunicação à ANPD; e
- Implementar as melhorias técnicas eventualmente necessárias, no cumprimento do **Plano**.

5.4. Todos os sócios, colaboradores e prestadores de serviços do GRUPO AZ

- Cumprir este Plano; e
- Informar quaisquer tipos de ocorrências sobre as quais possa recair qualquer tipo de suspeita de ser consideradas uma falha de segurança ou um incidente de segurança.

6. RESPOSTA TÉCNICA AO INCIDENTE

O **Time de Tecnologia** deverá estruturar equipe de resposta ao **Incidente** ocorrido, através da formação de uma **Equipe Multidisciplinar de Atendimento**, que inclui, pelo menos, pessoas responsáveis:

- Alta Direção
- Tecnologia/Segurança (interno, externo ou terceiro especialista)
- Recursos Humanos (*se envolvidos dados de funcionários*)
- Pela área afetada
- Departamentos adicionais com base no tipo de dados envolvidos, a depender do caso.

Poderá ser contratada equipe externa (forense, perícia, investigação digital, jurídica ou outros) para prestar suporte técnico para identificação, resposta e gestão do incidente.

Para **Resposta do Incidente**, serão acionados, adicionalmente, os responsáveis por:

- Jurídico (interno, externo ou terceiro especialista)
- Relacionamento/Marketing (para confecção de comunicados)
- Data Protection Officer
- Gestão de crises (opcional) (interno, externo ou terceiro especialista)

6.1. Etapas de Resposta ao Incidente

6.1.1. Recebimento de comunicação de incidente

Qualquer um do GRUPO AZ e/ou da comunidade pode realizar a comunicação de incidente de segurança, através de quaisquer canais de comunicação oferecidos pelo GRUPO AZ, que incluem canais humanos e canais técnicos de monitoramento, por exemplo:

- Canal de Suporte
- E-mails corporativos de colaboradores e prestadores de serviços do GRUPO AZ
- WhatsApp
- Google Chat
- E-mail de Privacidade (lgpd@azi.com.br / dpo@efcaz.com.br)
- E-mail da Data Protection Officer (mariana.costa@azi.com.br / mariana@tbarbosa.com.br)
- Redes sociais do GRUPO AZ
- Ferramentas de monitoramento (EDR, firewall gerenciado ou soluções equivalentes)

E outros oficiais, eventualmente disponibilizados.

6.1.2. Avaliação da situação e acionamento do Plano de Resposta e Gestão de Incidentes

Após o recebimento de denúncia sobre a ocorrência de um possível incidente, a comunicação recebida deve ser imediatamente enviada para o e-mail de Privacidade, podendo ou não ser acionada

diretamente a **Pessoa Gestora do Time de Tecnologia** para menção de urgência. É competência da **Pessoa Gestora do Time de Tecnologia** a avaliação da natureza da situação denunciada e definição se há elementos, de pronto, para ser considerado um incidente de dados ou uma falha de segurança.

ENTENDA A DIFERENÇA

 **Falha de segurança** é uma fraqueza ou vulnerabilidade de um sistema que pode ser explorada para ocasionar um incidente de segurança.

 **Incidente de segurança** é um evento ou uma série de eventos prejudiciais, resultantes da exploração de uma fraqueza ou vulnerabilidade.

A análise crítica da **Pessoa Gestora do Time de Tecnologia** (**ANEXO I - MODELO DE REGISTRO DE POTENCIAL INCIDENTE**) deve ser enviada para a **Alta Direção**, complementada com avaliação da pessoa **Data Protection Officer**, se houver dados pessoais envolvidos. Na análise, haverá a recomendação de acionamento ou não deste **Plano**. Isso porque a ocorrência de uma *falha de segurança* deve ser documentada e corrigida, mas não demanda o acionamento deste **Plano**.

Instruída com a recomendação da Pessoa **Gestora do Time de Tecnologia**, é responsabilidade e atribuição da **Alta Direção** realizar o acionamento do **Plano** ou solicitar mais evidências para decidir. Neste último caso, a **Pessoa Gestora do Time de Tecnologia** poderá complementar a ocorrência para decisão pela Alta Direção.

Acionado o **Plano**, será criado um *dossiê* administrativo sobre o tema (**ANEXO II - MODELO DE REGISTRO DE INCIDENTE DE SEGURANÇA**) conforme modelos anexos, a ser preenchido pelo **Time de Tecnologia** e demais pessoas envolvidas na investigação e resposta do incidente, conforme o caso.

6.1.3. Triagem

O **Incidente de Segurança** deverá ser triado para ser determinada a gravidade das suas consequências imediatas e mediatas. São consequências gravíssimas e prioritárias para o GRUPO AZ:

- Nível de perigo para a vida humana
- Impacto na reputação da empresa
- Paradas ou danos nas operações
- Proteção de informações confidenciais
- Limitação de perdas financeiras
- Manutenção da integridade da infraestrutura
- Relacionamento com outras atividades contínuas relacionadas ou não à segurança das informações

Essa etapa será devidamente registrada para entendimento futuro sobre a resposta dada pelo GRUPO AZ no enfrentamento do **Incidente de Segurança**.

6.1.4. Investigação e análise

A etapa de investigação e análise deverá ser investigativa para análise completa do incidente para o GRUPO AZ, a partir da identificação e registro das seguintes informações:

- A descrição do incidente;
- os tipos de dados envolvidos;
- o número de indivíduos internos/externos e/ou organizações impactados;
- A análise para determinação da causa do incidente;
- As medidas necessárias para sua resolução e mitigação.

Para análise do impacto, recomenda-se a utilização dos seguintes critérios:

Impacto	Descrição da escala de danos
Muito alto	• Todos os serviços estão parados • Há informações relevantes expostas, tais como dados pessoais e/ou outros dados classificados como confidenciais • A perda financeira é alta
Alto	• Os principais serviços estão bloqueados • Há informações relevantes expostas, tais como dados pessoais e/ou outros dados classificados como confidenciais • A perda financeira é considerável
Moderado	• O impacto nos serviços é parcial; • Não há informações relevantes expostas (dados pessoais e outros dados confidenciais); e • A perda financeira é pequena.
Baixo	• O impacto nos serviços principais é possível.

A **Pessoa Gestora do Time de Tecnologia** e a **Data Protection Officer** poderão acordar diferentes critérios dos sugeridos na tabela acima, desde que devidamente justificados e aprovados pela **Alta Direção**.

6.1.5. Contenção, Erradicação e Recuperação

6.1.5.1. Contenção

A etapa de contenção é crucial para impedir ou minimizar os efeitos do incidente. Essas ações ajudam a limitar o impacto do incidente e impedir que ele se espalhe, permitindo uma resposta mais eficaz e controlada do GRUPO AZ sobre a ocorrência. As ações podem incluir, dentre outras que forem identificadas pela **Pessoa Gestora do Time de Tecnologia** e a **Data Protection Officer**:

- **Aplicação de Patches:** Atualizar sistemas com patches de segurança para corrigir vulnerabilidades conhecidas.

- **Monitoramento Contínuo:** Implementar ferramentas de monitoramento para identificar e bloquear atividades suspeitas em tempo real.
- **Desativação de Contas:** Desativar contas comprometidas ou suspeitas para impedir acessos não autorizados.
- **Controle de Acesso:** Ajustar permissões e aplicar políticas de acesso mais restritivas para minimizar riscos.
- **Quarentena de Sistemas:** Isolar sistemas e dispositivos infectados até que sejam completamente analisados e limpos.
- **Políticas de Senhas:** Implementar políticas de senhas fortes e forçar a alteração de senhas para contas afetadas.
- **Configuração de Firewalls:** Ajustar regras de firewall para bloquear tráfego suspeito ou malicioso.
- **Remoção de Mídia Externa:** Proibir o uso de dispositivos de armazenamento externos (pen drives, discos rígidos externos) que possam estar infectados.
- **Desativação de Serviços:** Parar temporariamente serviços não essenciais que possam ser afetados pelo incidente.
- **Análise de Logs:** Revisar logs de segurança para identificar atividades suspeitas e pontos de entrada.
- **Notificação de Controladores:** Se o incidente for relacionado ao tratamento de dados controlados por parceiros, ele deverá ser comunicado tão logo haja certeza sobre a ocorrência do incidente, para adotar as medidas preventivas necessárias em seus próprios sistemas.

6.1.5.2. Erradicação

Essas ações ajudam a garantir que a causa raiz do incidente seja completamente eliminada, prevenindo recorrências e fortalecendo a segurança dos sistemas:

- **Identificação e Remoção de Malware:** Utilizar ferramentas especializadas para detectar e remover qualquer software malicioso presente nos sistemas.
- **Reparo de Sistemas:** Corrigir falhas e vulnerabilidades nos sistemas afetados para garantir que não sejam exploradas novamente.
- **Substituição de Hardware:** Substituir componentes de hardware comprometidos que possam estar infectados ou danificados.
- **Atualização de Softwares:** Garantir que todos os softwares estejam atualizados com as últimas correções e patches de segurança.
- **Revisão de Configurações de Segurança:** Ajustar configurações de segurança em todos os sistemas para eliminar pontos fracos e fortalecer a defesa.
- **Revisão de Políticas e Procedimentos:** Atualizar políticas e procedimentos de segurança com base nas descobertas do incidente.
- **Revalidação de Contas e Credenciais:** Verificar e atualizar todas as contas e credenciais para garantir que estejam seguras e não comprometidas.
- **Desativação de Acesso Não Autorizado:** Identificar e desativar qualquer acesso não autorizado aos sistemas.
- **Monitoramento Contínuo de Sistemas:** Implementar ou reforçar o monitoramento contínuo para detectar atividades suspeitas e garantir que o incidente foi completamente erradicado.

- **Teste e Verificação:** Realizar testes de segurança para verificar se as medidas de erradicação foram eficazes e garantir que o sistema esteja livre de ameaças.

6.1.5.3. Recuperação

- **Restauração de Backups:** Utilizar backups seguros para restaurar dados e sistemas comprometidos. É essencial garantir que esses backups estejam livres de malware e sejam atualizados e testados regularmente.
- **Verificação de Integridade dos Sistemas:** Executar verificações completas para assegurar que todos os sistemas estejam íntegros e não apresentem vestígios de comprometimento.
- **Reconfiguração de Sistemas:** Ajustar configurações e políticas de segurança para evitar vulnerabilidades similares no futuro. Isso pode incluir a implementação de novas regras de firewall, ajustes em permissões de acesso, entre outros.
- **Testes de Segurança:** Realizar testes rigorosos de penetração e avaliações de vulnerabilidades para garantir que as medidas implementadas sejam eficazes e o ambiente esteja seguro.
- **Monitoramento Contínuo:** Implementar ou reforçar sistemas de monitoramento para detectar rapidamente qualquer atividade suspeita ou anômala após a recuperação. Isso ajuda a identificar possíveis ameaças remanescentes.
- **Comunicação com Stakeholders:** Informar todas as partes interessadas sobre o progresso da recuperação, as medidas adotadas e os resultados dos testes de segurança. A transparência é crucial para a manutenção da confiança com as partes relevantes.
- **Documentação de Processos:** Registrar detalhadamente todas as ações tomadas durante a recuperação para futuras referências e aprimoramento de processos. Isso inclui o que foi feito, quando foi feito, por quem e quais foram os resultados.
- **Treinamento da Equipe:** Oferecer sessões de treinamento para a equipe sobre as lições aprendidas e as novas práticas de segurança. A educação contínua é fundamental para prevenir futuros incidentes.
- **Atualização de Procedimentos e Políticas:** Revisar e atualizar políticas de segurança e procedimentos operacionais com base nas lições aprendidas durante o incidente. Isso pode envolver a criação de novos protocolos de resposta a incidentes ou a revisão de práticas de segurança existentes.
- **Revisão Pós-Incidente:** Conduzir uma análise completa do incidente e das ações de recuperação para identificar oportunidades de melhoria. Isso pode incluir a revisão de falhas no processo, a eficácia das medidas de contenção e a identificação de lacunas na segurança.

Essas medidas são cruciais para garantir uma resposta eficaz e rápida aos incidentes de segurança, minimizando os impactos e fortalecendo a resiliência do GRUPO AZ.

7. REGISTRO DO INCIDENTE

Concluídas as fases para resposta técnica do incidente, a equipe responsável deverá elaborar relatório de registro contendo, no mínimo, as informações abaixo.

7.1. Identificação dos Sistemas e Bases de Dados Afetados

- **Lista de Sistemas Comprometidos:** Identificar todos os sistemas, aplicações e bancos de dados afetados pelo incidente.
- **Impacto Operacional:** Descrever como o incidente afetou a operação desses sistemas e quais funcionalidades foram comprometidas.
- **Localização dos Sistemas:** Informar a localização física ou lógica dos sistemas afetados (ex.: servidores locais, nuvem).

7.2. Descrição do Problema ou da Atividade

- **Natureza do Incidente:** Detalhar o tipo de incidente que ocorreu (ex.: ataque de phishing, infecção por malware, acesso não autorizado).
- **Linha do Tempo do Incidente:** Fornecer uma cronologia detalhada dos eventos desde a detecção até a resolução do incidente.
- **Métodos de Detecção:** Explicar como o incidente foi detectado (ex.: alertas de sistemas de monitoramento, denúncias internas).
- **Ações Tomadas:** Descrever as medidas imediatas adotadas para conter, erradicar e recuperar o incidente.

7.3. Lições Aprendidas e Medidas Adotadas

- **Lições Aprendidas:** Identificar os principais aprendizados decorrentes do incidente. Isso pode incluir falhas nos procedimentos de segurança, necessidade de treinamento adicional, ou melhorias em ferramentas de monitoramento.
- **Medidas Adotadas:** Detalhar as ações específicas implementadas para evitar a repetição do incidente. Isso pode incluir:
 - **Atualização de Softwares:** Instalação de patches e atualizações.
 - **Revisão de Políticas de Segurança:** Atualizações nas políticas de acesso e uso de sistemas.
 - **Melhoria de Infraestrutura:** Investimento em novas ferramentas e tecnologias de segurança.
 - **Treinamento e Capacitação:** Programas de treinamento para funcionários sobre práticas de segurança e resposta a incidentes.

8. PLANO DE COMUNICAÇÃO

Após confirmação do incidente, em paralelo com os procedimentos de resposta a registro, deverá ser estruturado plano de comunicação pelos responsáveis pelo marketing, Data Protection Officer e time Jurídico do GRUPO AZ para definição da necessidade e a forma da comunicação do incidente para:

8.1. Stakeholders Internos

Notificação Imediata: Informar todos os funcionários e departamentos relevantes sobre o incidente assim que ele for detectado. Isso garante que todos estejam cientes e possam tomar as devidas precauções.

Relatórios de Progresso: Fornecer atualizações regulares sobre o progresso da contenção, erradicação e recuperação do incidente. Transparência é essencial para manter a confiança e colaboração.

8.2. ANPD (Autoridade Nacional de Proteção de Dados)

O incidente de segurança envolvendo dados pessoais poderá ser comunicado à Autoridade Nacional de Proteção de Dados – ANPD quando, alternativamente:

- **Risco ou dano relevante aos titulares** de dados pessoais;
- O GRUPO AZ está na posição de Controlador de Dados Pessoais.

Deve ser considerado que **a avaliação de risco ou dano irrelevante para os titulares** não exclui a necessidade de manutenção de registro adequado e monitoramento sobre a evolução do risco/dano, se houver.

8.2.1. Registro Prévio no Sistema de Peticionamento Eletrônico

O **Data Protection Officer** poderá ter ou selecionar terceiro que tenha registro pessoal e intransferível no Portal de Peticionamento Eletrônico indicado pela Autoridade Nacional de Proteção de Dados como ambiente de inserção de comunicados e movimentação de processos administrativos perante a Autoridade.

8.2.2. Levantamento de Informações

Após a confirmação do incidente, cabe ao responsável pela comunicação levantar os aspectos de privacidade da sua ocorrência, descritos abaixo, os quais serão comunicados à ANPD:

- A descrição da natureza dos dados pessoais afetados;
- As informações sobre os titulares envolvidos;
- A indicação das medidas técnicas e de segurança utilizadas para a proteção dos dados, observados os segredos comercial e industrial;
- Os riscos relacionados ao incidente;
- Os motivos da demora, no caso de a comunicação não ter sido imediata; e
- As medidas que foram ou que serão adotadas para reverter ou mitigar os efeitos do prejuízo.

Indica-se que essas informações sejam obtidas diretamente com os responsáveis pela resposta técnica ao incidente ou por meio do relatório elaborado pela equipe técnica.

O comunicado à ANPD tem caráter informativo e técnico, na medida em que serão avaliadas também as ferramentas do GRUPO AZ para evitar, enfrentar e prevenir novos incidentes de segurança com dados pessoais.

8.2.3. Formulário de Comunicação à ANPD

A comunicação deverá ocorrer por meio do envio preenchido de formulário fornecido pela própria autoridade fiscalizadora.

Na ocasião do envio do formulário, deve ser anexada comprovação de legitimidade para representação do GRUPO AZ junto à ANPD, como procuração específica ou termo de nomeação do Encarregado atestando os poderes conferidos pela empresa para representação no caso.

8.2.4. Comunicação às Partes Relevantes

O GRUPO AZ deverá analisar se:

- É controladora dos dados pessoais, sendo que, se não for, deve imediatamente comunicar o controlador; e, se for,
- A ocorrência do incidente envolvendo dados pessoais resulta em risco ou dano relevante aos titulares dos dados afetados.

Em caso positivo, a empresa deverá comunicá-los.

Deve ser considerada a existência de risco ao titular de dados pessoais sempre que incidente envolver:

- dados pessoais sensíveis;
- dados pessoais de indivíduos vulneráveis como incapazes, crianças, adolescentes etc.; e
- dados com potencial de ocasionar: danos materiais ou morais, violação de imagem e/ou da privacidade do titular, danos à reputação, roubos de identidade e fraudes financeiras.

Da mesma forma, deve-se considerar o volume de dados envolvido, a quantidade de indivíduos afetados, a boa-fé e as intenções dos terceiros que eventualmente tiveram acesso aos dados após o incidente e a facilidade de identificação dos titulares por terceiros não autorizados.

O comunicado aos titulares deve conter, ao menos, as seguintes informações:

- Resumo e data da ocorrência do incidente;
- Descrição dos dados pessoais afetados;
- Riscos e consequências aos titulares de dados;
- Medidas tomadas pela empresa e as recomendadas aos titulares para mitigar os efeitos do incidente, se cabíveis; e
- Canal de Comunicação para onde os titulares podem solicitar informações adicionais a respeito do incidente.

A comunicação deverá ser feita, preferencialmente, mediante contato direto com os titulares afetados, pelo canal mais conveniente à empresa (e-mail, telefone, WhatsApp etc.).

Excepcionalmente, quando a notificação individual for inviável, a empresa poderá publicar comunicado oficial no seu site.

8.2.5. Clientes e Parceiros

Informação Precisa e Pontual: Notificar clientes e parceiros sobre o incidente, destacando as ações tomadas para proteger seus dados e minimizar impactos.

Instruções de Segurança: Fornecer orientações sobre medidas que clientes e parceiros podem tomar para proteger suas informações pessoais durante e após o incidente.

Colaboração com Controladores: Fornecer as informações necessárias para os controladores cumprirem suas obrigações de tratamento de dados, sempre resguardando segredos de software, a propriedade intelectual, dados comerciais e outros que não possam ser compartilhados pela sua natureza confidencial.

9. TESTES E EXERCÍCIOS DE SIMULAÇÃO

O Plano de Gestão e Resposta de Incidentes de Segurança deverá ser testado periodicamente, por meio de exercícios de simulação, para verificar sua efetividade e o nível de prontidão das equipes envolvidas.

9.1. Periodicidade

Os testes deverão ocorrer, no mínimo, uma vez por ano, ou sempre que houver alterações relevantes na infraestrutura tecnológica, na estrutura organizacional ou nas principais ameaças identificadas para o GRUPO AZ.

9.2. Cenários de Teste

Os cenários de simulação devem contemplar, sempre que possível:

- Incidentes envolvendo indisponibilidade de sistemas críticos;
- Incidentes envolvendo vazamento ou exposição indevida de dados pessoais; e/ou
- Incidentes decorrentes de engenharia social, phishing ou credenciais comprometidas, de acordo com o procedimento próprio.

9.3. Registro e Avaliação dos Testes

Cada exercício deverá gerar relatório específico contendo:

- Cenário testado;
- Áreas envolvidas;
- Principais ações executadas;
- Dificuldades encontradas;
- Lições aprendidas;

- Melhorias propostas no processo, nas ferramentas ou na capacitação das equipes.

Os relatórios de teste integram as evidências deste Plano e deverão ser considerados na revisão anual prevista na seção “REVISÃO”.

10. LIÇÕES APRENDIDAS

Após o fechamento do registro de incidente e realização das comunicações devidas, o Responsável pelo acionamento do Plano de Resposta a Incidentes deve apresentar Relatório de Análise Crítica sobre o incidente e o cumprimento deste plano para a Alta Direção.

11. REVISÃO

Este **Plano** será revisado anualmente e sempre que necessário, para que reflita as mudanças na estrutura do GRUPO AZ.

ANEXO I - MODELO DE REGISTRO DE POTENCIAL INCIDENTE

1. Informações Básicas

- **Data e Hora da Detecção:** [Inserir data e hora exatas]
- **Nome do Relator:** [Inserir nome completo]

2. Descrição do Potencial Incidente

- **Descrição Resumida:** [Inserir uma descrição breve e objetiva do potencial incidente]
- **Causa Suspeita:** [Descrever a causa provável do potencial incidente]

3. Avaliação Inicial

- **Impacto Estimado:** [Breve descrição do impacto potencial, se conhecido]
- **Sistemas e Dados Atingidos (se aplicável):** [Listar os sistemas e bases de dados potencialmente afetados]
- **Se há Dados Pessoais envolvidos:** [Listar os tipos de dados pessoais e as categorias de titulares potencialmente afetados]

4. Decisão do Gestor de Tecnologia

- **Avaliação do Gestor:** [Descrever se o gestor de tecnologia aceita ou rejeita a avaliação inicial]
- **Recomendação do Gestor à Alta Direção:** [Indicar se recomenda acionar o Plano de Resposta e Gestão de Incidentes]

5. Ações Imediatas (se necessário)

- **Medidas Tomadas:** comunicação à DPO e à Alta Direção.

ANEXO II - MODELO DE REGISTRO DE INCIDENTE DE SEGURANÇA**MODELO DE REGISTRO DE INCIDENTE DE SEGURANÇA****1. Informações Gerais do Incidente**

- **Data e Hora da Detecção:** [Inserir data e hora exatas]
- **Nome do Relator:** [Inserir nome completo]
- **Departamento:** [Inserir departamento responsável]
- **Contato:** [Inserir informações de contato]

2. Descrição do Incidente

- **Descrição Completa:** [Inserir uma descrição detalhada do incidente, incluindo como foi detectado e os sintomas observados]
- **Tipo de Incidente:** [Selecionar uma das opções: Acesso Não Autorizado, Malware, Phishing, DDoS, etc.]
- **Localização:** [Inserir a localização física ou lógica afetada pelo incidente]

3. Impacto do Incidente

- **Sistemas Atingidos:** [Listar todos os sistemas afetados]
- **Bases de Dados Atingidas:** [Listar todas as bases de dados comprometidas]
- **Localização Geográfica das Bases de Dados Atingidas:** [Listar a localização das bases de dados comprometidas]
- **Serviços Impactados:** [Descrever os serviços e operações impactados pelo incidente]
- **Escopo do Impacto:** [Descrever a extensão do impacto, como número de usuários afetados, áreas impactadas, etc.]
- **Impacto na Continuidade do Negócio:** [Descrever como o incidente afeta a continuidade operacional]
- **Gravidade do Incidente:** [Classificar como Alta, Média ou Baixa]

4. Ações Imediatas de Contenção

- **Medidas Tomadas:** [Descrever as ações imediatas tomadas para conter o incidente]
- **Data e Hora das Ações:** [Inserir data e hora exatas das ações de contenção]
- **Responsáveis pelas Ações:** [Inserir nomes e cargos dos responsáveis pelas ações de contenção]

5. Análise de Causa Raiz

- **Causa Identificada:** [Descrever a causa raiz do incidente]
- **Métodos Utilizados:** [Detalhar como o incidente foi conduzido ou quais vulnerabilidades foram exploradas]
- **Data da Identificação:** [Inserir data da identificação da causa raiz]
- **Responsáveis pela Análise:** [Inserir nomes e cargos dos responsáveis pela análise de causa raiz]

6. Ações de Erradicação e Recuperação

- **Medidas de Erradicação:** [Descrever as ações tomadas para eliminar a causa raiz do incidente]
- **Medidas de Recuperação:** [Descrever as ações tomadas para restaurar os sistemas e dados afetados]
- **Data e Hora das Ações:** [Inserir data e hora exatas das ações de erradicação e recuperação]
- **Responsáveis pelas Ações:** [Inserir nomes e cargos dos responsáveis pelas ações de erradicação e recuperação]

7. Comunicação do Incidente

- **Stakeholders Internos Informados:** [Listar os departamentos e pessoas informadas internamente]
- **Shareholders Informados:** [Listar os acionistas informados e os meios de comunicação utilizados]
- **ANPD Informada:** [Confirmar se a ANPD foi informada e fornecer detalhes do relatório enviado]
- **Clientes e Parceiros Informados:** [Descrever as comunicações realizadas com clientes e parceiros]

8. Lições Aprendidas

- **Principais Lições:** [Descrever as lições aprendidas com o incidente]
- **Oportunidades de Melhoria:** [Listar as oportunidades de melhoria identificadas]
- **Ações Corretivas Implementadas:** [Descrever as ações corretivas implementadas para prevenir futuros incidentes]
- **Plano de Treinamento:** [Descrever as iniciativas de treinamento baseadas nas lições aprendidas]

9. Feedback e Melhorias Contínuas

- **Coleta de Feedback:** [Descrever o processo de coleta de feedback das partes envolvidas]
- **Revisão Periódica:** [Propor um cronograma de revisões periódicas do plano de resposta a incidentes]
- **Atualizações de Políticas e Procedimentos:** [Detalhar as atualizações necessárias nas políticas e procedimentos de segurança]

10. Aprovação e Revisão

- **Responsável pela Revisão:** [Inserir nome e cargo do responsável pela revisão do registro]
- **Data da Revisão:** [Inserir data da revisão]
- **Aprovação pela Alta Direção:** [Inserir nomes e cargos dos membros da alta direção que aprovaram o registro]



(10.12.2025) Plano de Resposta e Gestao de Incidentes .pdf

Código do documento: VC53-GTGV-Q23A-7LWL

**Autenticação Eletrônica**

Valide em <https://app-sign.efcaz.com.br/flowbee-pub/#!/validar/VC53-GTGV-Q23A-7LWL>

Ou digite o código: VC53-GTGV-Q23A-7LWL

Assinado em conformidade à Medida Provisória nº 2.200-2/2001 e Lei 14.063/2020.

Assinaturas



Eletrônica

elias.mendonca@azi.com.br

e*****ca@azi.com.br

elias.mendonca@azi.com.br

Gestor



Eletrônica

Paulo Cesar Pizzo Sorato

p*****to@azi.com.br

Paulo C. P. Sorato

Representante Legal



Registro eventos

18/12/2025 15:26

elias.mendonca@azi.com.br

Assinou como Gestor. Documento: 887.***.***.**.

Data nascimento: 10/02/1980. Email: e*****ca@azi.com.br. IP: 200.241.189.50. Localização: Cidade: null, Estado: null. Nível de segurança: Validado por código único enviado por e-mail.

RUBRICA

e.

18/12/2025 16:18

Paulo Cesar Pizzo Sorato

Assinou como Representante Legal. Documento: 050.***.***.**.

Data nascimento: 28/04/1963. Email: p*****to@azi.com.br. IP: 200.241.189.50. Localização: Cidade: null, Estado: null. Nível de segurança: Validado por código único enviado por e-mail.

RUBRICA

P.C.P.S.

Hash do documento original: 4618b5f827c0023c9c53ba5e787f24ef2f36dc849838298818e8b7f5733b6633

Hash do documento assinado: 527cf2266048d93c9611def2dee203efa623c9e77346c5ab423b88737b0550f8
